DLT GXP SUPPLIER ASSESSMENT KIT

Free Sample

The method on two pages and four example questions with their findings, taken unchanged from the kit.

Document	DLT-GXP-SAMPLE-1.3
Kit version	1.3
Evidence cut-off of the examples	12 November 2026
Publisher	Tau HUD (tauhud.com)
Status	Sample. Free to pass on unchanged.

What this is. A quality unit that is asked to use a distributed ledger or a rule engine in a regulated process has to assess the supplier and the intended use. The kit is a working template for that assessment, with a method guide and two worked examples. This sample shows how it works. It is not regulatory or legal advice, it certifies nothing, and the publisher is not affiliated with IDNI AG, whose public software serves as the example.

1 The method in short

No authority certifies a ledger or a rule engine as 'GxP compliant'. The regulated company validates a system for one intended use and assesses its suppliers. The kit therefore starts with the use, and every later step refers back to it.

Step	What you do	Result
1 Scope	Write down one intended use, its exclusions, the records and signatures involved, impact, novelty and reliance.	The depth of assessment the use needs
2 Components	List what you would run or rely on, with versions and who supplies each part.	A baseline that can be named in a decision
3 Responsibilities	Assign each area to yourself, the supplier, an operator or a service provider.	Who has to answer which question
4 Questionnaire	Decide which of the 77 questions apply and send each to the party named for it.	Answers, each with an evidence status
5 Evidence	Register every item with its type: supplier statement, observed property, document, own verification.	A statement is never mistaken for a test
6 Records	Describe each regulated record over its whole life, including export and archive.	The record model for validation
7 Risks	Score the 24 risk prompts that apply. Severity, occurrence and detectability give a priority class.	What needs a control or an explicit decision
8 Decision	The decision authority decides and signs. The workbook counts what is open. It does not decide.	A decision record with conditions and review triggers

1.1 Outcomes, and no score

Each answer gets one of five outcomes. There is no total score, because a score invites adding up a missing signature control against a good backup.

- **Acceptable**: the evidence is adequate for the stated use.
- **Acceptable with conditions**: adequate only together with a named control or action.
- **Evidence requirement not met**: the evidence this use needs was not obtained. The practice may well exist. Ask for it.
- **Confirmed gap**: the evidence shows the capability or practice is absent for this baseline and this use.
- **Pending**: not yet assessed.

The difference between the third and the fourth outcome matters for fairness to a supplier. An open-source project that was never asked has not failed anything.

1.2 Assessment depth

A screening of public sources is the lowest depth. It can support a negative decision or show what must be requested. In this method it can never support an approval. Both worked examples in the kit are such screenings, which is why neither ends with an approval.

2 Four example questions

The kit holds two worked examples on the same engine and two very different uses. In the first, a public test network would be the authoritative record of a batch decision (use U1). In the second, the engine runs offline as a tool that looks for contradictions in written process rules, and a person confirms what it reports (use U2). The four entries below are copied from the filled workbooks.

Interest statement: the publisher of this kit runs tauhud.com, a community site that follows Tau Net and operates a testnet node. It is not affiliated with IDNI AG.

2.1 Who decides what is valid

Field	Entry
Question D1	What is the operating model (private, consortium, public)? Who operates the validators, how many are there, and under which participation rules?
Asked of	Network operator
Evidence to request	Validator list with operators; participation policy
References	Annex 11 §3.1; draft Annex 11 §7.1, §7.3
Example	U1, a public test network as the record
Answer found	Public proof-of-authority network: validators that the manufacturer does not control decide which entries are valid. Genesis lists one active validator key; validators are added through governance. Operators are not named in the sources.
Evidence status	Public sources only
Outcome	**Confirmed gap**
What was established	The network is operated by validators outside the manufacturer's control. Validator set at genesis: one key; changes need governance votes.
What remains unverified	Current validator set and operators.

2.2 What the supplier says about maturity

Field	Entry
Question B8	What does the supplier state about the product's maturity and the uses it is, or is not, intended for?
Asked of	Software supplier; Engine supplier
Evidence to request	Product status statement; documented limitations
References	Annex 11 Principle; draft Annex 11 §2.8, §6.3
Example	U2, the engine as an offline rule checker
Answer found	The supplier states that the Tau language is work in progress, that releases are currently in an alpha state and can contain bugs, and that the features described can have performance issues.
Evidence status	Public sources only
Outcome	**Confirmed gap**
What was established	The supplier's own description: work in progress, alpha.
What remains unverified	Whether and when a release intended for production use is planned.

2.3 Test evidence for a release

Field	Entry
Question B5	Which regression, negative and error-path tests run for a release, and is the test evidence kept per release?
Asked of	Software supplier
Evidence to request	Test plan; test report for the baseline you will use
References	Annex 11 §4.7; draft Annex 11 §9.4, §9.6; SSDF PW.8
Example	U2, the engine as an offline rule checker
Answer found	The repository holds unit, integration, API and command-line tests. The Dockerfile has a stage that builds the program and runs the tests, and a stage that runs them with the address sanitizer. The test workflow starts on pull requests. No test report for the assessed commit is published as a document.
Evidence status	Public sources only
Outcome	**Acceptable with conditions**
What was established	An automated test suite exists and is part of the published build.
What remains unverified	Pass state at the assessed commit; negative and error-path coverage for the operations U2 uses.

2.4 Handling of vulnerabilities

Field	Entry
Question H3	How are vulnerabilities reported, triaged, fixed and disclosed (policy, contact, target times, advisories)?
Asked of	Software supplier
Evidence to request	Security policy; advisory history
References	SSDF RV.1, RV.2; draft Annex 11 §7.5(vii), §15.13
Example	U2, the engine as an offline rule checker
Answer found	No security policy, security contact or advisory process was found in the repository. Issues are reported in the public tracker.
Evidence status	Public sources only
Outcome	**Evidence requirement not met**
What was established	Nothing is published on vulnerability handling.
What remains unverified	Contact, triage, target times, advisories.

In the kit each entry also names its evidence items, and every statement about the software is tied to a file and a line range at one pinned commit. The citations were checked by script.

3 What the full kit contains

File	Content
Method guide (PDF and Word)	The method in full: scope, depth, evidence types, the risk method and its rules, the decision record, reassessment.
Assessment template (Excel workbook)	77 questions, 24 risk prompts and 82 requirement rows with their references, a responsibility matrix, evidence and source registers, a decision record with status counters.
Example 1: Tau Net as a record	Report and filled workbook for use U1.
Example 2: Tau Language as a rule checker	Report and filled workbook for use U2.
Verification record	How the workbook formulas were tested, in two calculation engines, with the results and the file hashes.

3.1 What it does not do

- It does not replace your own validation, your own supplier audit or your own legal review.
- It quotes no paid standards. The requirement rows paraphrase free official sources and name them, so that you read the original.
- The examples rest on public sources only. The supplier was not contacted and no software was run for them.
- The kit has been verified by its publisher as described in its verification record. It has not been reviewed by an independent expert.

3.2 Where to find it

The free summary of both examples, with every source linked, is at tauhud.com/gxp/. The kit is offered on the same page.